V43 – IAM och identitet

SAMUEL LISSBRO Mitt repo:https://github.com/95samlis/AWS-MOV25/tree/main

Syfte

Syftet med uppgiften är att konfigurera IAM i AWS för att styra vilka användare, grupper och tjänster som får åtkomst till olika resurser. Med hjälp av policies och roller tillämpas principen om least privilege, vilket innebär att varje användare och tjänst endast får de behörigheter som behövs.

Översikt över IAM-behörigheter

Identitet	Resurs	Behörigheter	Syfte
dev-erik	S3-bucket	Lista, läsa, ladda upp och radera objekt	Hantera utvecklingsfiler
drift-david	EC2-instans	Visa instanser, starta och stoppa en specifik instans	Hantera drift
novatrix-ec2-s3-read	S3-bucket	Lista och läsa objekt	Låta EC2 läsa filer från S3

Princip: Varje identitet får endast de behörigheter som behövs för dess uppgift. Användarna får sina behörigheter via IAM-grupper, medan EC2 får åtkomst genom en IAM-roll.

Användare och grupper

Jag skapade två IAM-grupper, `Utveckling` och `Drift`, samt två användare som representerar respektive arbetsområde. Användarna placerades i rätt grupp för att behörigheter senare ska kunna tilldelas via grupperna.

Skapa grupper och användare:

```
aws iam create-group --group-name Utveckling
aws iam create-group --group-name Drift

aws iam create-user --user-name dev-erik
aws iam create-user --user-name drift-david
```

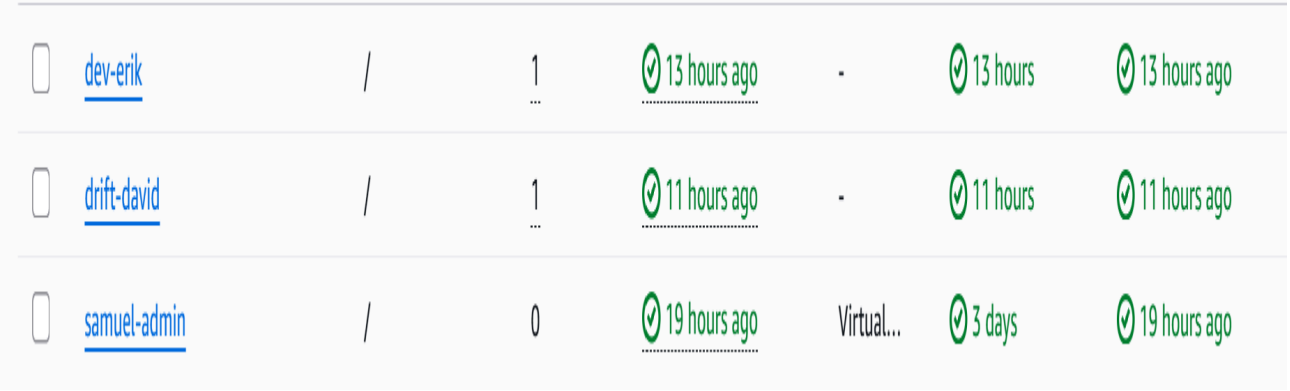
Koppla användarna till grupperna:

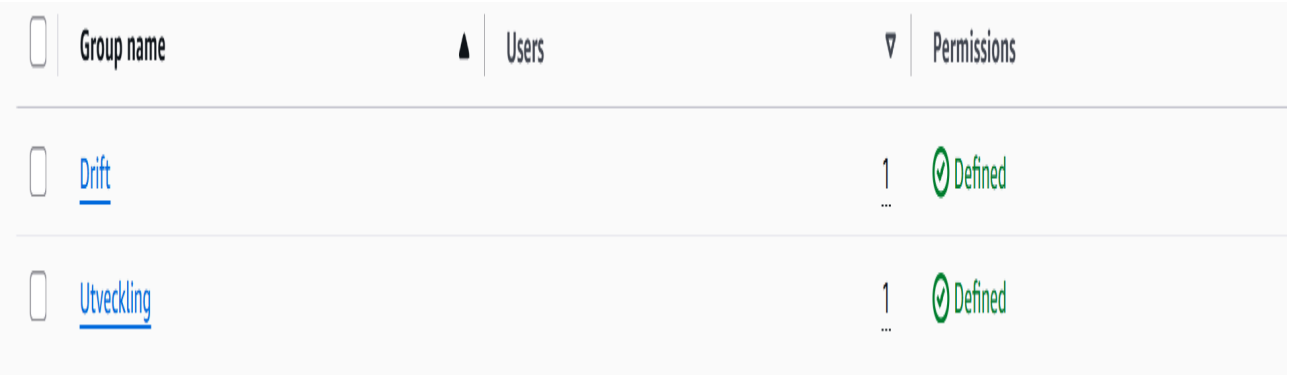
```
aws iam add-user-to-group \
  --user-name dev-erik \
  --group-name Utveckling
```

```
aws iam add-user-to-group \
  --user-name drift-david \
  --group-name Drift
```

Det fullständiga skriptet finns i `iam-users-groups.sh`. Skriptet kontrollerar om grupper och användare redan finns innan de skapas.

Verifiering





Policies enligt least privilege

Policyn `novatrix-drift-ec2` ger gruppen `Drift` rätt att visa EC2-instanser och starta eller stoppa en specifik instans.

Policyn `novatrix-utveckling-s3` ger gruppen `Utveckling` rätt att lista, läsa, ladda upp och radera filer i S3-bucketen.

Utveckling – S3

Koden visar vilka saker gruppen får göra med filer i S3.

```
"Action": [
  "s3:GetObject",
  "s3:PutObject",
  "s3:DeleteObject"
],
"Resource": "arn:aws:s3:::novatrix-data-90sali-01/*"
```

Drift – EC2

Koden visar att gruppen får starta och stoppa den valda EC2-instansen.

```
"Action": [
  "ec2:StartInstances",
  "ec2:StopInstances"
],
"Resource": "arn:aws:ec2:eu-north-1:017636909046:instance/i-
04a5c42a35df25db4"
```

Koppla policies till grupper

Kommandona kopplar rätt policy till rätt grupp.

```
aws iam attach-group-policy \
  --group-name Utveckling \
  --policy-arn "$DEV_POLICY_ARN"

aws iam attach-group-policy \
  --group-name Drift \
  --policy-arn "$DRIFT_POLICY_ARN"
```

Hela skriptet: `iam-policies.sh`

Verifiering

Bilderna visar vilka behörigheter som tilldelats grupperna Utveckling och Drift samt att åtkomsten är begränsad till rätt AWS-resurser.

Utveckling – S3

Service	Access level	Resource	Request condition
S3	Limited: List, Read, Write	Multiple	None

Read (1 of 83)

Action	Resource	Request condition
GetObject	BucketName| string like |novatrix-data-90sali-01, ObjectPath| string like |All	None

Drift – EC2

Action	Resource	Request condition
StartInstances	region| string like |eu-north-1, InstanceID| string like |i-04a5c42a35df25db4	None
StopInstances	region| string like |eu-north-1, InstanceID| string like |i-04a5c42a35df25db4	None

Allow (1 of 477 services)

Service	Access level	Resource	Request condition
EC2	Limited: List, Write	Multiple	None

Behörigheter mellan tjänster

Jag skapade IAM-rollen `novatrix-ec2-s3-read` så att EC2-instansen kan läsa filer från S3. På så sätt behöver servern inga egna åtkomstnycklar.

1. IAM-roll och behörighet Rollen tillåter EC2 att använda den. Policyn ger rätt att lista innehållet i S3-bucketen och läsa objekt.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Service": "ec2.amazonaws.com"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

2. S3-policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::novatrix-data-90sali-01"
    },
    {
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::novatrix-data-90sali-01/*"
    }
  ]
}
```

3. Koppla rollen till EC2

Skriptet skapar en instance profile, lägger IAM-rollen i den och kopplar profilen till EC2-instansen.

```
aws ec2 associate-iam-instance-profile \
  --region "$REGION" \
  --instance-id "$INSTANCE_ID" \
  --iam-instance-profile "Name=${PROFILE_NAME}"
```

Hela skriptet finns i `ec2-roles.sh`.

Motivering: EC2 får bara lista och läsa från den angivna S3-bucketen. Det följer least privilege och begränsar åtkomsten till det som servern behöver.

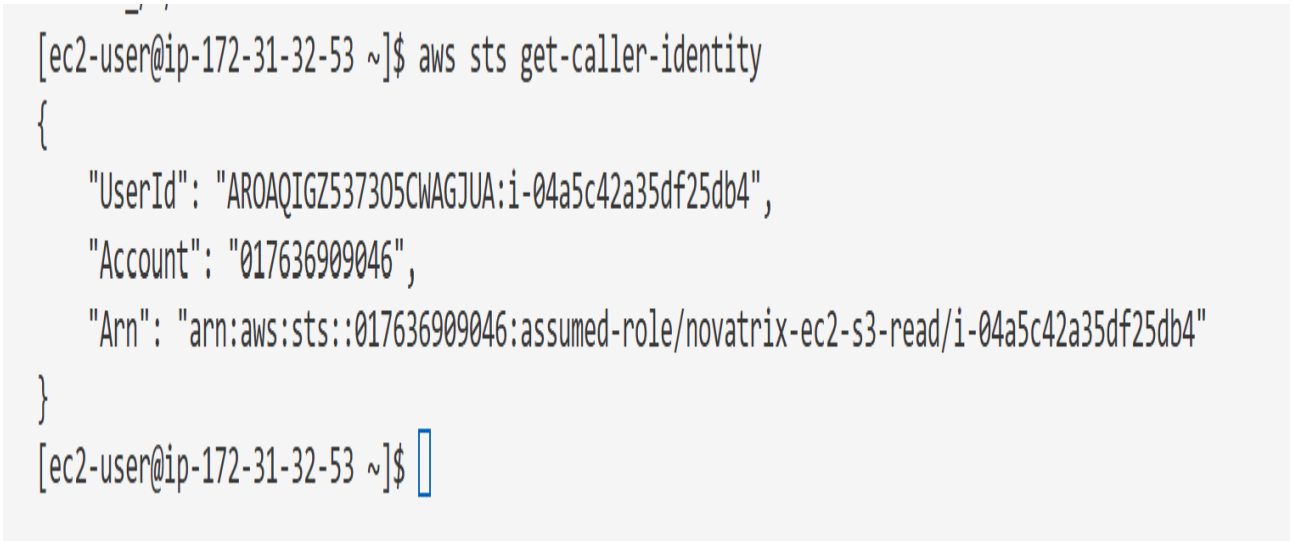
Verifiering

Jag använde följande kommandon på EC2-instansen för att kontrollera rollen och testa åtkomsten till S3.

```
aws sts get-caller-identity
aws s3 ls s3://novatrix-data-90sali-01/
```

Bild 1 – Verifiering av IAM-roll:

Kommandot `aws sts get-caller-identity` visar att EC2-instansen använder rollen `novatrix-ec2-s3-read`.



Bilderna visar att EC2 använder IAM-rollen `novatrix-ec2-s3-read` och kan lista filer i S3-bucketen. Policyn begränsar åtkomsten till att lista och läsa objekt i den angivna bucketen.

S3-policy:

Permissions defined in this policy Info

Permissions defined in this policy document specify which actions are allowed or de

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": "s3:ListBucket",
            "Resource": "arn:aws:s3:::novatrix-data-90sali-01"
        },
        {
            "Effect": "Allow",
            "Action": "s3:GetObject",
            "Resource": "arn:aws:s3:::novatrix-data-90sali-01/*"
        }
    ]
}
```

Test från EC2:

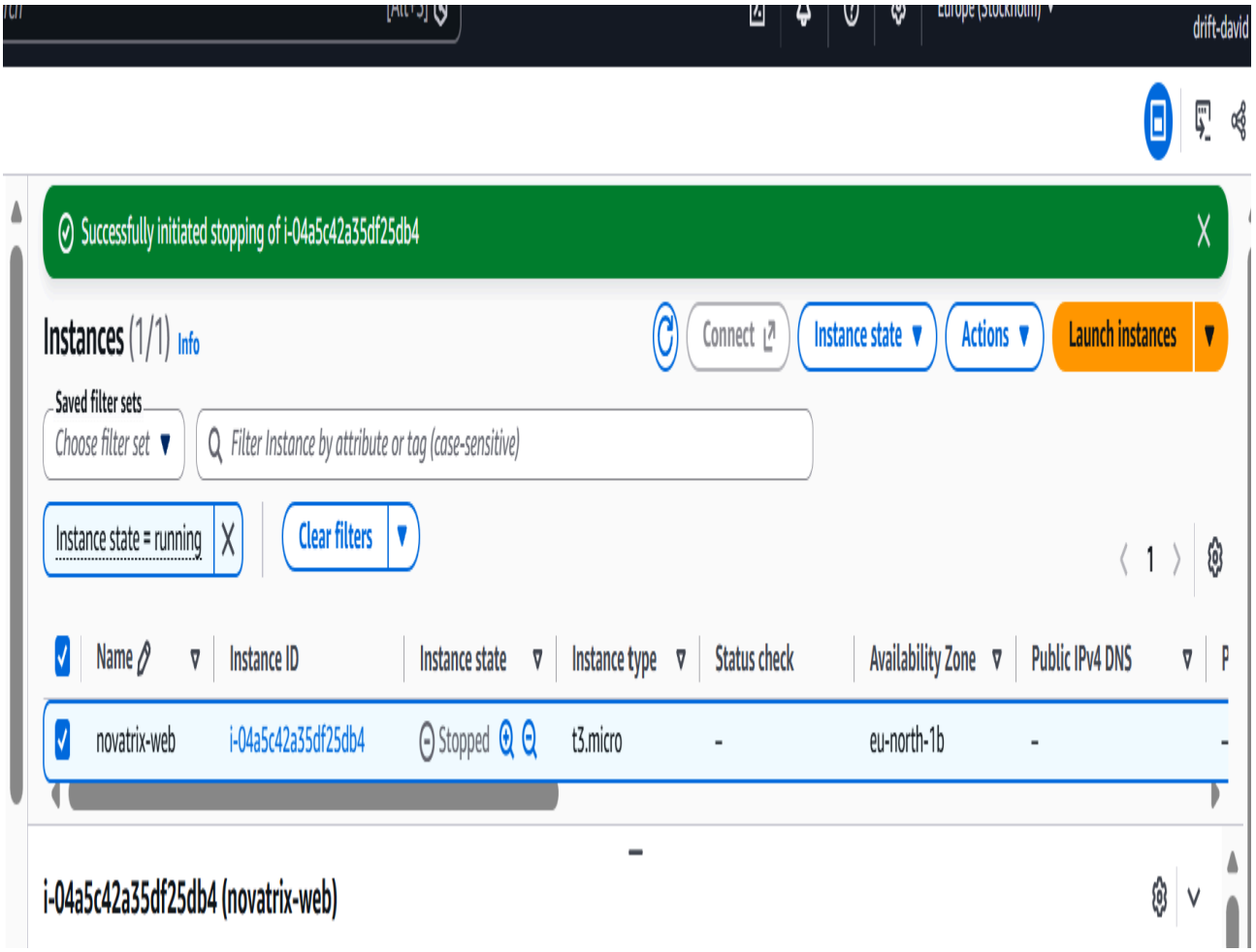
```
[ec2-user@ip-172-31-32-53 ~]$ aws sts get-caller-identity
{
    "UserId": "AROAQIGZ5373O5CWAGJUA:i-04a5c42a35df25db4",
    "Account": "017636909046",
    "Arn": "arn:aws:sts::017636909046:assumed-role/novatrix-ec2-s3-read/i-04a5c42a35df25db4"
}
[ec2-user@ip-172-31-32-53 ~]$ aws s3 ls s3://novatrix-data-90sali-01/
2026-10-28 22:40:11    1108515 Free-download-Nature-Image-1.jpg
[ec2-user@ip-172-31-32-53 ~]$
```

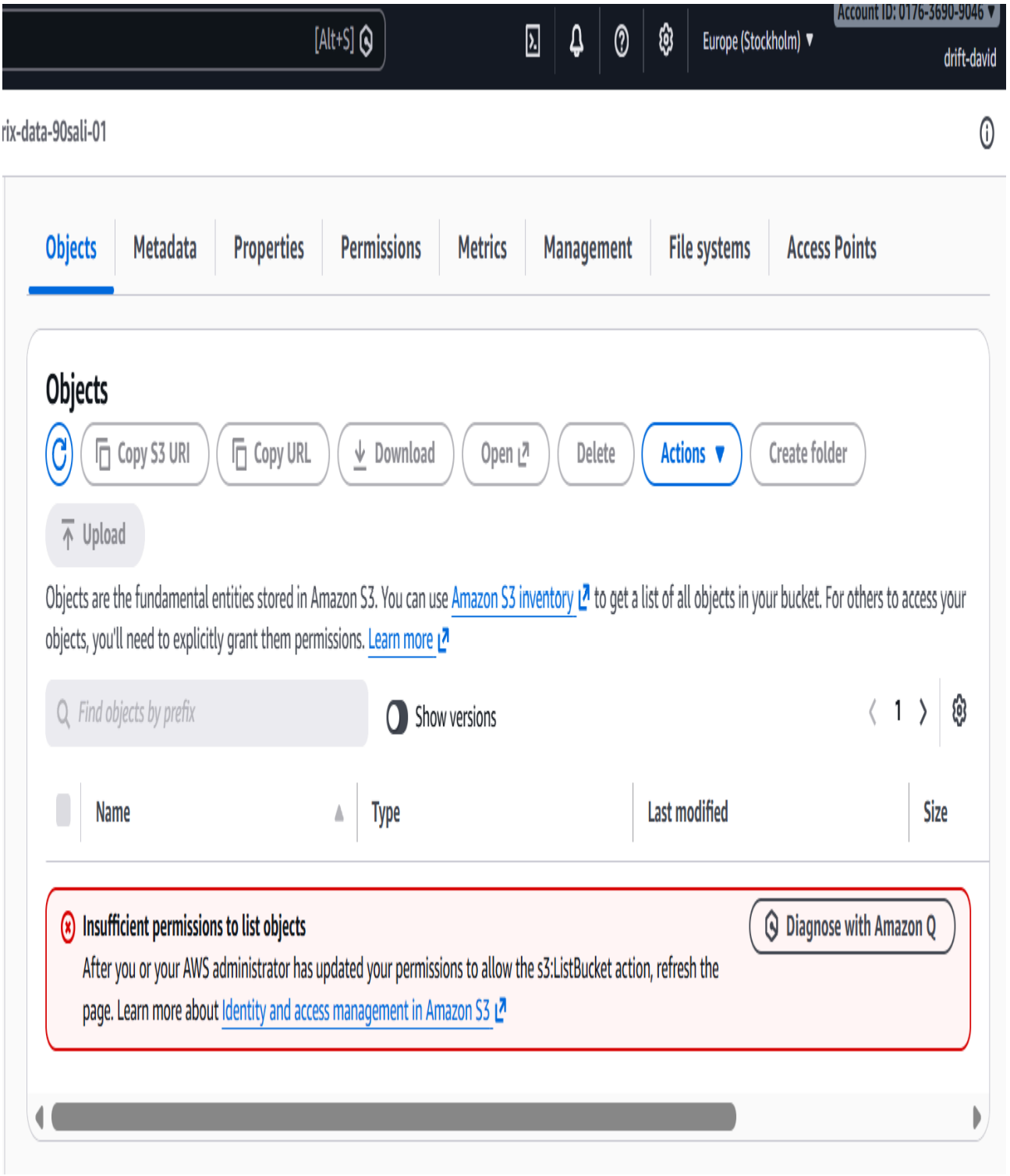
Motivering

EC2 får endast läsa från den aktuella S3-bucketen. Det begränsar åtkomsten till det som servern behöver och följer principen least privilege.

Verifiering av IAM-behörigheter för Drift och Utveckling

Jag testade användaren `drift-david` i AWS-portalen. Han kunde stoppa EC2-instansen `novatrix-web`, men fick inte åtkomst till S3-bucketen.

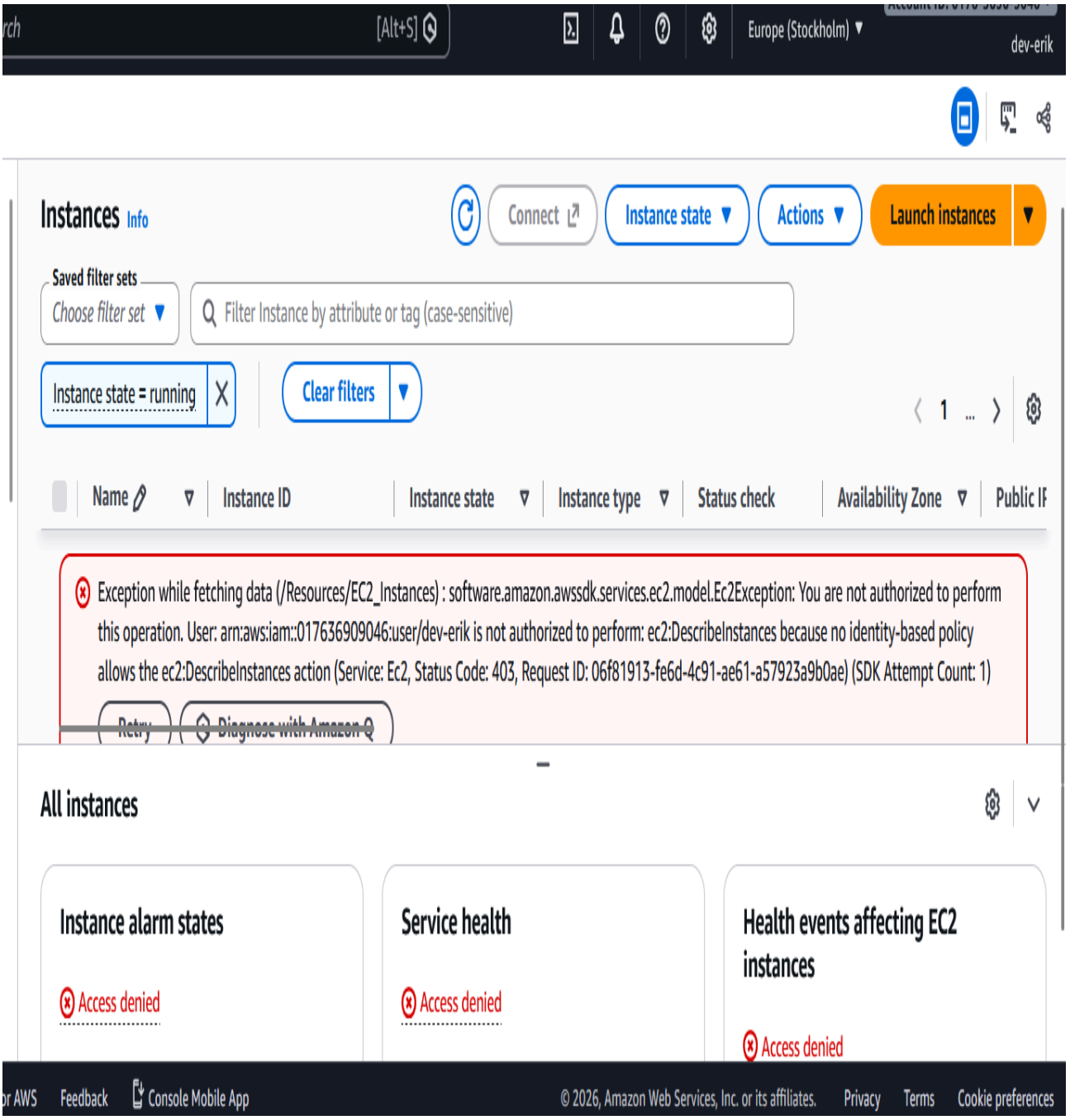

drift-david
Successfully initiated stopping of i-04a5c42a35df25db4
Instances (1/1) Info
Connect
Instance state
Actions
Launch instances
Saved filter sets
Choose filter set
Filter instance by attribute or tag (case-sensitive)
Instance state = running
Clear filters
1
Name
Instance ID
Instance state
Instance type
Status check
Availability Zone
Public IPv4 DNS
novatrix-web
i-04a5c42a35df25db4
Stopped
t3.micro
-
eu-north-1b
-
i-04a5c42a35df25db4 (novatrix-web)

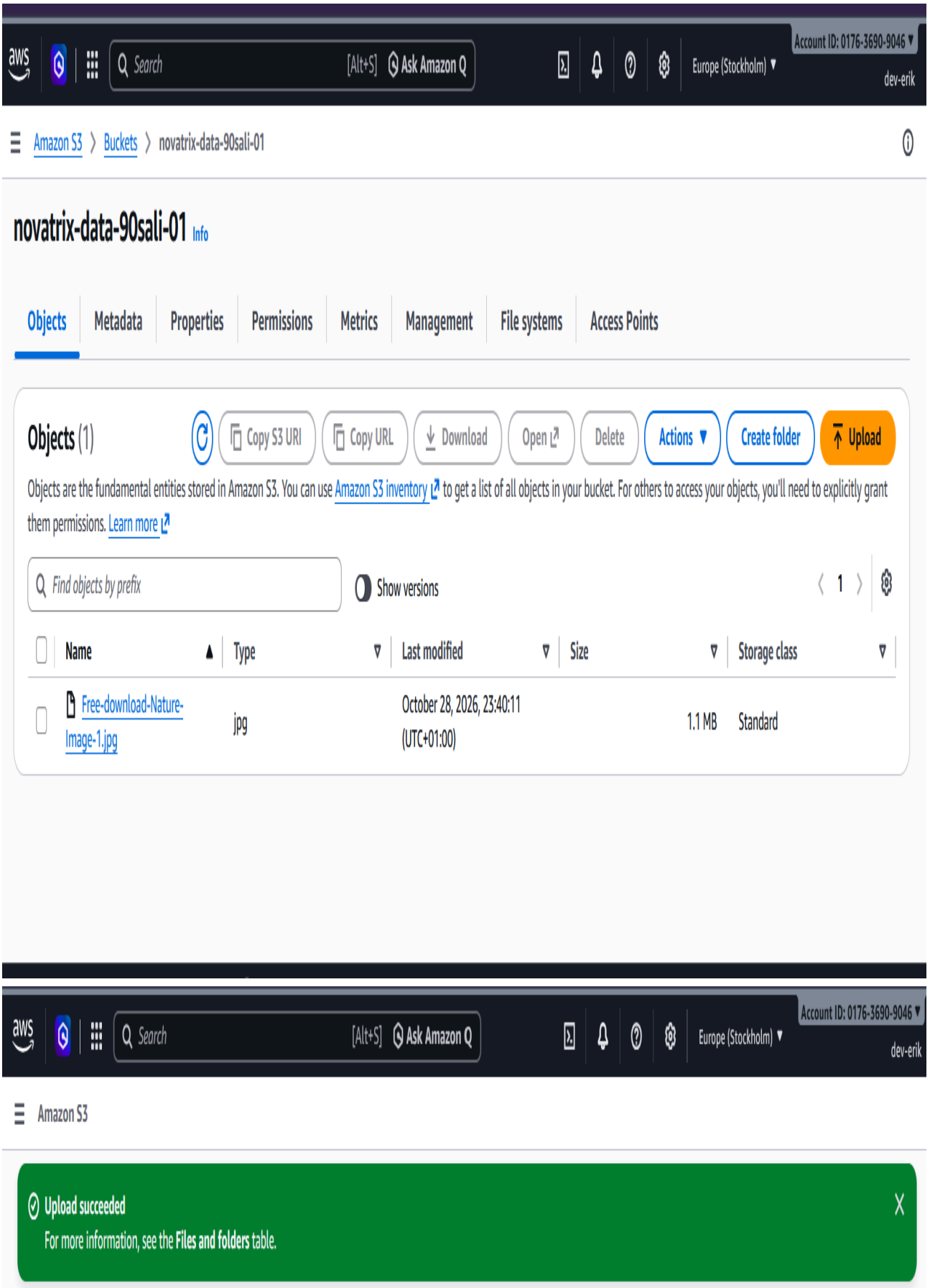


Motivering: Drift ska kunna starta och stoppa servern vid behov, men behöver inte hantera filer i S3. Därför får användaren bara de behörigheter som behövs för driftarbetet.

Test av användaren `dev-erik`

Jag testade användaren `dev-erik` i AWS-portalen. Han kunde se filerna i S3-bucketen och ladda upp en fil, men nekades åtkomst till EC2.


[Alt+S]
Europe (Stockholm)
dev-erik
Instances Info
Connect
Instance state
Actions
Launch instances
Saved filter sets
Choose filter set
Filter Instance by attribute or tag (case-sensitive)
Instance state = running
Clear filters
1 ...
Name
Instance ID
Instance state
Instance type
Status check
Availability Zone
Public IP
Exception while fetching data (/Resources/EC2_Instances) : software.amazon.awssdk.services.ec2.model.Ec2Exception: You are not authorized to perform this operation. User: arn:aws:iam::017636909046:user/dev-erik is not authorized to perform: ec2:DescribeInstances because no identity-based policy allows the ec2:DescribeInstances action (Service: Ec2, Status Code: 403, Request ID: 06f81913-fe6d-4c91-ae61-a57923a9b0ae) (SDK Attempt Count: 1)
Retry
Diagnose with Amazon Q
All instances
Instance alarm states
Access denied
Service health
Access denied
Health events affecting EC2 instances
Access denied
Feedback
Console Mobile App
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences



Motivering: Utveckling behöver kunna läsa och hantera filer i S3 för sitt arbete, men behöver inte starta eller stoppa servrar. Därför har användaren S3-behörigheter men inte EC2-behörigheter. Det följer principen least privilege.